



Seven Common Sense Rules of Security

Group 7 by BSIT-4B

Seven Common Sense Rules of Security

1. “Avoid storing sensitive files online, and use encryption and compression to protect important data like trade secrets, personnel, and payroll information.”
2. “Prevent unauthorized access by applying security patches and staying updated through vendor bulletins and security forums.”

Seven Common Sense Rules of Security

3. “Secure your system to prevent hackers from using it as a base, especially by protecting shared directories, group accounts, and weak passwords.”
4. “Use security tools (e.g., Tripwire, Crack, SATAN, tcpd, COPS) to monitor Internet-connected systems and detect intrusions.”

Seven Common Sense Rules of Security

5. “Regularly review security tool reports to address minor issues before they escalate into major problems.”
6. “Learn operating system security yourself instead of relying solely on costly consultants who may exaggerate risks.”

Seven Common Sense Rules of Security

7. “Regularly check for and investigate unusual activity (odd logs, unexpected account behavior, activity at strange times).”

The background features a complex, abstract design. It consists of a network of thin, dark lines that resemble circuit traces or data paths. These lines are interconnected with several solid black circles, which could represent nodes, data points, or connection points. The overall aesthetic is technical and futuristic, with a monochromatic color scheme of greys, blacks, and whites. The design is symmetrical and fills the entire frame, creating a sense of depth and complexity.

Account Security

Account Security

- Password security is one of the most important areas the system manager has to monitor.
- Many users chose poor passwords.
- Many other users have no password on their account.
- Most users resist changing their passwords.

Account Security

- One method which can increase account security is to use an authentication system such as **Kerberos**
 - Kerberos uses DES encryption of “tickets” (much like an AFS token) to authenticate a user.
 - Kerberos replaces the password program and sends encrypted passwords (or challenge results) over the network.
 - Kerberos can be set up such that all data is encrypted on the network.
 - Kerberos is becoming more popular, and is being included in more Operating Systems.

Account Security

- The best security tool at any site is an alert administrator.
 - Watch for users logging in at odd hours, or logged in while they are on vacation.
 - Watch for off-site logins by local users.
 - Scan the password file to look for users with UID or GID of zero.



File Permission

File Permission

- Once you have established reasonable access security for a system you need to look at the system binaries to ensure they are secure.
 - Are there any world writable directories on the system?
 - Are there setuid or setgid programs on the system?
 - Have the modify dates on system binaries changed inexplicably?
 - Search path security must be a concern for root.
 - Never put “.” in the root path.

File Permission

- Once you make the system files secure, you have to look at what the users do with their accounts.
 - Are the user home directories “locked up”?
 - Do the users have setuid programs in their path?
 - If the user is in multiple groups, are the group permissions set correctly?

The background features a complex, abstract design. It consists of a network of thin, black, angular lines that resemble circuit traces or data paths. These lines are set against a light gray background that is overlaid with a pattern of faint, concentric circles, giving it a technical or digital feel. The overall aesthetic is modern and high-tech.

Data Encryption

Data Encryption

- One cheap method of providing security is to use some form of data encryption for sensitive files.
- crypt is standard on UNIX systems, but is easy to break.
- The standard UNIX passwords are encrypted with crypt.
- Linux/BSD use MD5 password encryption.
- One of the major flaws of crypt is that many strings may encrypt to the same encrypted value, hence password crackers don't have to have exact matches of a password, just something that encrypts to the same value!

Data Encryption

- If you use crypt, compress the data first. Compressed data is usually un-intelligible, so someone trying to de-crypt compressed data will have a harder time cracking the data.
 - DES encryption utilities are available in the United States. They provide a very good encryption method, but are very difficult to deal with (most Operating Systems do not provide nice methods of incorporating DES encryption).
 - pgp - Pretty Good Privacy - uses a much better encryption method than crypt (and some say better than DES), but is sometimes cumbersome to use. It is easier to tie pgp into the Operating System than DES utilities..

The background features a complex, abstract design. It consists of a network of thin, black, angular lines that resemble circuit traces or a stylized map. These lines are set against a light gray background. Interspersed among the lines are several circular elements, some of which are solid black and others are white with black outlines. The overall effect is a high-tech, digital aesthetic.

Security Tools

Security Tools

The System administrator can take security one step further by using several public domain tools to periodically scan passwords, system and user files looking for vulnerabilities:

- oCOPS - (Computer Oracle and Password System) checks file/directory/device permissions, monitors the password and group files, monitors the system startup scripts and crontab files, and mails the administrator a report.
- crack - password cracking program.
- SATAN/SAINT - checks well-known security holes in system binaries, and tries many means of gaining access to systems.
- Nessus - New Satan-like scanner (more thorough).

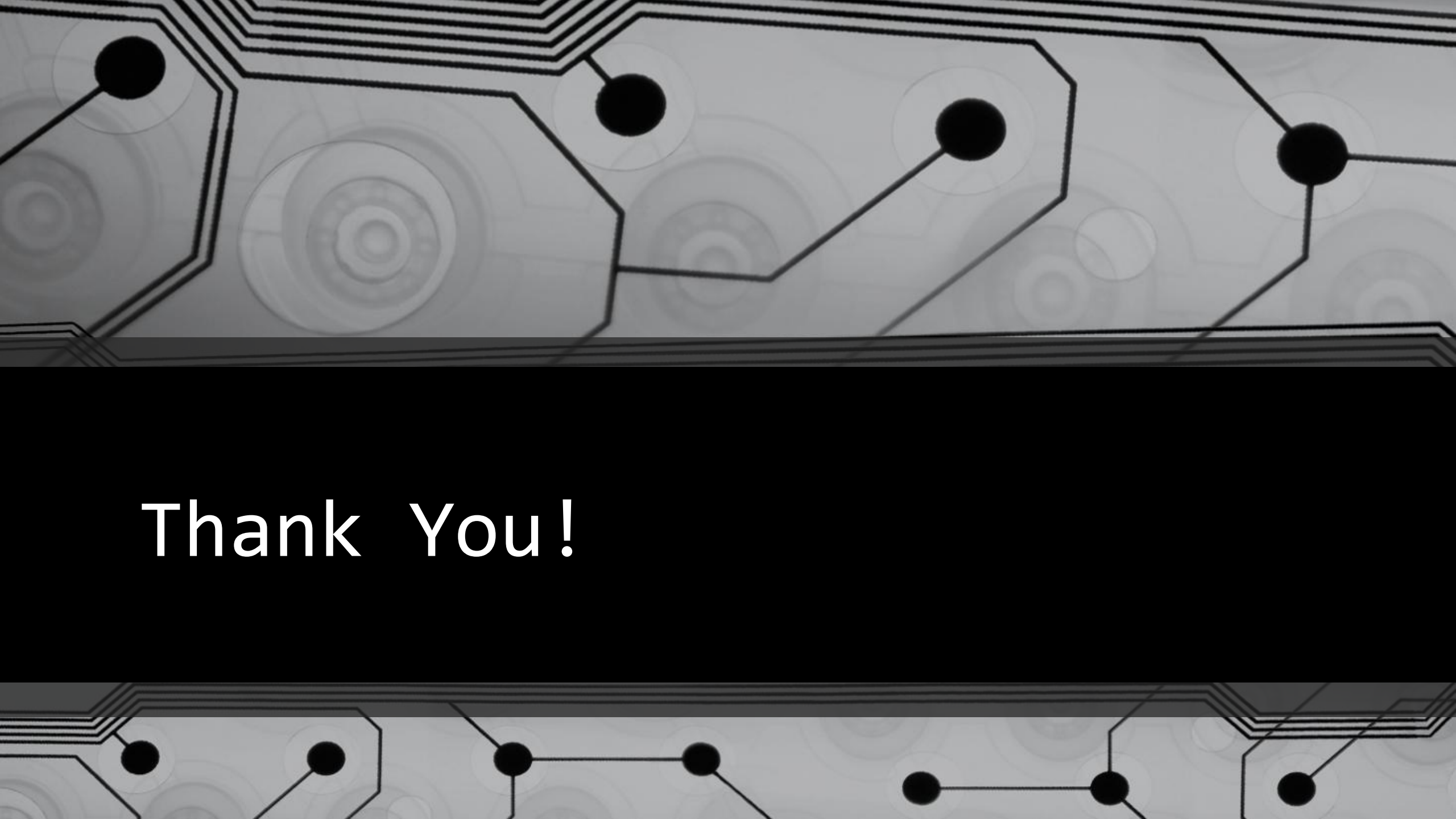
Security Tools

- Nmap – port scanner.
- tcpd - a TCP wrapper that provides logging for many TCP/IP programs.
- TRIPWIRE - computes checksums for files, stores them in a database, then on subsequent runs checks to ensure the checksums have not changed. If checksum has changed the administrator get a report and can look at the files in question.
- tiger - another SATAN clone from Texas A&M
- courtney - yet another SATAN clone
- the hackers tools - from rootshell, bugtraq, 2600, lopht, underground web sites.

Security Tools

There are many audit tools available for free download.

- The Center for Internet Security offers tools to check Solaris, Windows, and Linux hosts, as well as routers for common security problems.
- The System Administration, Networking, and Security Institute (SANS) has several tools for system auditing, and step-by-step guides to follow to secure your systems.
- The CERT organization publishes guidelines for system security.



Thank You!